

Scenario 04 — Clone Systems SEUXDR

Trainee handbook

🕒 Estimated time: **2 hours** · 🎯 Level: **Intermediate** · 🏢 Sector: **ICT security vendor (CRA manufacturer)**

Scenario brief

You have been brought in as an **independent conformity assessor**.

Clone Systems manufactures **SEUXDR**, a self-hosted SIEM/XDR platform with local-LLM remediation. It is classified under the Cyber Resilience Act as an **Annex III important product with digital elements, Class I**. The company has just finished a remediation programme and is telling its board that the product is **70% CRA ready — 21 of 30 objectives compliant**.

Your job is not to take that on trust. It is to **verify the claim from the artefacts, and find what is still missing**.

You have:

- CyberFort credentials for a tenant with **CRA mode enabled** (<https://access.cyber-fort.eu>).
- The product source at the release under assessment — `SEUXDR 3.4.0`, branch `cra/remediation-sprint-1`. Your instructor will give you `seuxdr-3.4.0-src.zip` or repository access.
- The manufacturer's own compliance pack in `docs/cra/` inside that source.

i **This scenario uses the remediated product only.** There is a deliberately broken baseline of the same product (`00a95ad`) used elsewhere in the pilot; you are not looking at it. Assessing a *compliant* product is the harder and more realistic skill — anyone can write up a product that fails everything. The discipline being taught here is evidencing a pass and being honest about what still fails.

Learning outcomes

By the end of this scenario you will be able to:

1. Verify a manufacturer's CRA product classification and say why self-assessment is or is not available.
2. Use the **SBOM Generator** to confirm a component-inventory claim rather than accept it.
3. Use **Dependency Check** and **Code Analysis** to test claims made in a compliance document against the code.
4. Confirm that Annex I Part II vulnerability-handling artefacts exist *and* say something useful about their quality.
5. Test an access-control claim behaviourally, not just by reading a policy.
6. Set the compliance status of all **30 CRA objectives** with evidence attached.
7. Identify the **residual gaps** a manufacturer's own summary tends to soften.

8. Export a conformity pack and write an assessor's opinion that a notified body could act on.

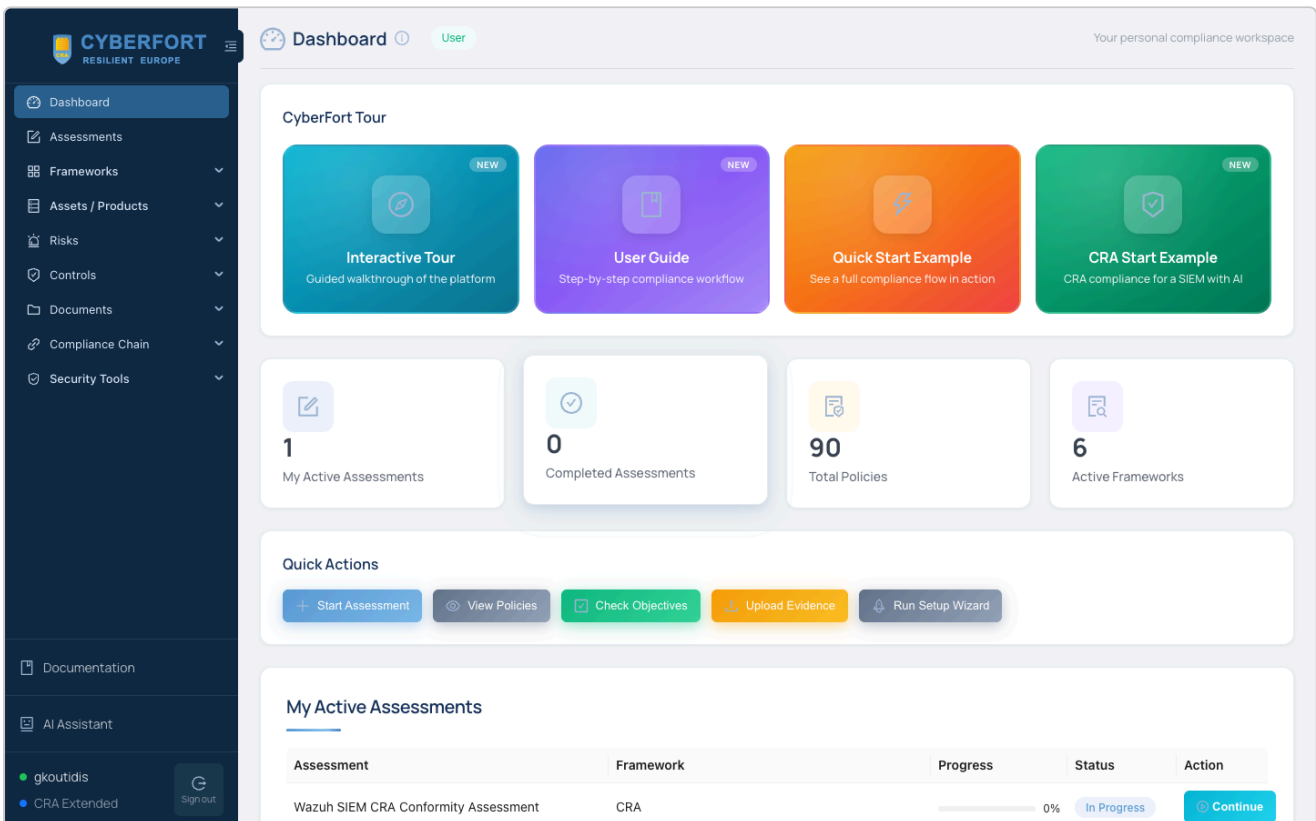
Step 0 — Get the source and confirm what you are assessing

You do **not** need the product running for most of this scenario. CyberFort's three source-side scanners take an archive or a repository URL, and they carry the bulk of the assessment.

```
unzip seuxdr-3.4.0-src.zip -d ~/assess && cd ~/assess
cat VERSION                      # expect: 3.4.0
head -20 CHANGELOG.md            # expect: [3.4.0] - 2026-07-30
git log --oneline -3             # if you were given repo access
```

 **Check the version claim first.** A Declaration of Conformity has to identify the product. Confirm `VERSION` exists and that the manager, agent and front end are reconcilable to it. Note what you find — the agent still declares `1.0.1` in its own configuration and the front end `package.json` still says `0.0.0`. Decide for yourself whether one `VERSION` file is sufficient *Product Identification* under Annex V, and write down your reasoning.

Sign in to CyberFort. The modules you will use are **Assets / Products**, **Security Tools**, **Frameworks** → **Objectives**, **Documents** and **Compliance Chain**.



The screenshot shows the CyberFort dashboard with a sidebar menu on the left containing: Dashboard, Assessments, Frameworks, Assets / Products, Risks, Controls, Documents, Compliance Chain, Security Tools, Documentation, and AI Assistant. The main content area includes a 'CyberFort Tour' section with four cards: Interactive Tour, User Guide, Quick Start Example, and CRA Start Example. Below this is a 'Quick Actions' section with buttons for Start Assessment, View Policies, Check Objectives, Upload Evidence, and Run Setup Wizard. The 'My Active Assessments' section displays a table with one assessment: Wazuh SIEM CRA Conformity Assessment, which is in progress (0% completion) and has a 'Continue' button.

Assessment	Framework	Progress	Status	Action
Wazuh SIEM CRA Conformity Assessment	CRA	0%	In Progress	Continue

Step 1 — Confirm the classification, and its consequence

Open **Assets / Products** → **Manage Assets** and find `SEUXDR`. Check the **Criticality** field.

Asset Management

Add New Asset

Details | CIA Matrix

Asset Name * SEUXDR Version 3.4

Asset Type * Software Product Status Active

Economic Operator Manufacturer Criticality Security information and event management (SIEM)...

CRA Vertical Profile Anti-Malware / Malware Detection Product

License Proprietary - Clone Systems commercial licence, 5-year IP Address / IP Range / URL 45.132.135.12

Justification Security information and event management (SIEM) system with automated AI-driven remediation. Listed in CRA Annex III as an important product with digital elements, Class I, therefore subject to Article 32(2) conformity assessment obligations.

Description Self-hosted SIEM/XDR platform for SME and mid-market operators. Collects and correlates security telemetry from Windows, Linux and macOS endpoint agents over mTLS, and applies a locally hosted LLM (Ollama) to generate and execute automated remediation actions - IP blocking, process termination and malicious-file quarantine - without sending customer telemetry to a third-party cloud.

SBOM (Software Bill of Materials) CycloneDX 1.5 SBOM generated per release by Security Tools > SBOM Generator (Syft); top-level Go modules, npm packages and base images tracked per build.

Cancel Save Asset

Name	Application	Status	Manufacturer	Last Updated
SEUXDR	Network	Active	Manufacturer	7/22/2026

It should read *Security information and event management (SIEM) systems*, under the group header **ANNEX III – IMPORTANT PRODUCTS WITH DIGITAL ELEMENTS – Class I**.

Now do the assessor's job: **test the classification instead of accepting it**. Read the product description and satisfy yourself that it is a SIEM. Then look for the other limbs — search the source for what the remediation actions actually do:

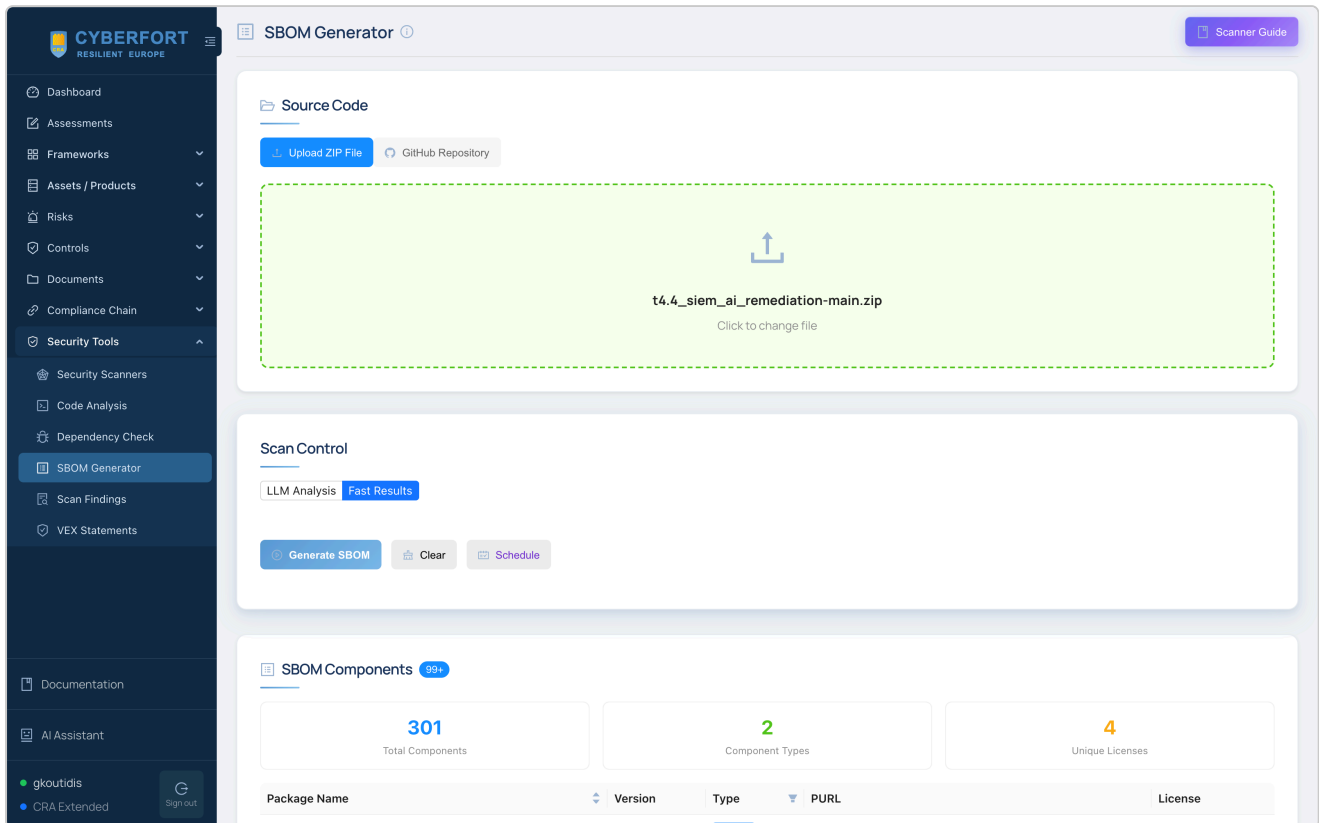
```
grep -rn "iptables -I INPUT\|netsh advfirewall\|pfctl" agent/active-response/ | head
grep -rn "rm -f\|DEL /F" agent/active-response/ | head
```

Residual gap #1 — the conformity route. SEUXDR qualifies as an important product on three independent Annex III limbs: it is a SIEM, it is an intrusion detection and prevention system, and it removes or quarantines malicious software. Under **Article 32(2)** that means a notified body must be involved — a Module A internal-control self-declaration is **not** available. Check whether the manufacturer has engaged one. They have not. This is the single largest open item and no amount of engineering closes it.

Step 2 — Verify the SBOM claim

The manufacturer claims a machine-readable SBOM is generated on every build. Test it.

Go to **Security Tools** → **SBOM Generator**, upload the archive, accept the authorisation disclaimer and click **Generate SBOM**.



Expect roughly **300 components** across a handful of licences. Then check the claim properly:

```
cat .github/workflows/security.yml | grep -A4 -i "sbom\|cyclonedx"
cat docs/cra/SBOM_POLICY.md | head -40
```

💡 Compare what the scanner found against what the policy promises. The policy commits to CycloneDX 1.5 covering **both** the Go module and the front end. Look at the component list the platform produced and ask whether Go modules are actually represented, or whether the inventory is predominantly npm. Write down the answer — this is exactly the kind of gap a notified body will probe.

Step 3 — Test the dependency and code claims

Security Tools → **Dependency Check**, same archive, **Run Scan**.

Timestamp	Target	Scan Type	Status	Severity	Duration (s)	User	Organization	Actions
> Jul 30, 2026, 02:40:10 PM	vulner...	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	[Icons]
> Jul 30, 2026, 02:40:10 PM	vulner...	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	[Icons]
> Jul 30, 2026, 01:49:30 PM	t4.4_si...	dependency_... scan	COMPLETED	N/A	34.15	gkoutidis@clone-syste...	Clone Systems	[Icons]
> Jul 30, 2026, 01:40:10 PM	vulner...	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	[Icons]
> Jul 30, 2026, 01:40:10 PM	vulner...	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	[Icons]
> Jul 30, 2026, 12:40:10 PM	vulner...	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	[Icons]
> Jul 30, 2026, 12:40:10 PM	vulner...	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	[Icons]
> Jul 30, 2026, 11:40:10 AM	vulner...	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	[Icons]

Then **Security Tools** → **Code Analysis** with the same archive.

Now read `docs/cra/DEPENDENCY_POLICY.md` and check whether the code matches the policy:

```
grep -nE "golang-migrate|gorilla/websocket|go-cache" go.mod
grep -n "faker" manager_front/package.json
grep -n "npm ci|npm install" manager_front/Dockerfile
grep -rn "S1lMfWxh1HB6SbKg" . --include=*.go
```

Residual gap #2 — the committed credential is gone from the code, not from history. The live admin password no longer appears in the working tree, but `docs/cra/SECRET_ROTATION.md` states plainly that it remains in git history and requires rotation plus a history rewrite. Verify the manufacturer has documented this rather than quietly dropped it. Credit them for the honesty; record it as open.

The dependency policy names a blocked-component register. Check that `gorilla/websocket` — which carries the remediation command channel — is on it, and note its version against what upstream ships.

Step 4 — Confirm the vulnerability-handling artefacts

Annex I Part II is where the baseline product failed hardest. Check each artefact exists and is real, not a stub:

```
ls -la SECURITY.md .well-known/security.txt CHANGELOG.md VERSION
ls .github/workflows/
ls docs/cra/
grep -n "24|72|ENISA" SECURITY.md | head
grep -n "support period|2031" docs/cra/PATCH_AND_SUPPORT_POLICY.md | head -5
```

You are looking for six things, and all six should be present:

Artefact	What good looks like
Security contact	A monitored address, not a placeholder
Disclosure timeline	Acknowledgement, triage and remediation windows by severity
Article 14 procedure	The 24-hour, 72-hour and 14-day ENISA deadlines named explicitly
SBOM in CI	Generated per build and attached to releases
Scanning in CI	<code>govulncheck</code> , <code>npm audit</code> , container scanning, secret scanning
Support period	At least five years, with an end date

💡 Cross-check one claim against the platform. Open **Documents** → **Technical File** → **Vulnerability Disclosure** and compare the six numbered requirements the CRA expects against what `SECURITY.md` actually commits to. A document that exists is not the same as a document that satisfies the requirement.

Dashboard

Assessments

Frameworks

Assets / Products

Risks

Controls

Documents

Compliance Chain

Security Tools

Documentation

AI Assistant

gkoutidis

CRA Extended

Sign out

Vulnerability Disclosure Policy

The **Cyber Resilience Act (CRA)** mandates that manufacturers of products with digital elements implement a coordinated vulnerability disclosure policy. This policy must provide a clear, accessible process for external parties to report vulnerabilities, and must ensure that discovered vulnerabilities are handled promptly and reported to the relevant authorities – including ENISA for actively exploited vulnerabilities.

1

Security Contact Point
Designate and publicly document a single point of contact for receiving vulnerability reports. This must be easily accessible and clearly communicated on the product website and in product documentation.

2

Disclosure Timeline
Define the coordinated vulnerability disclosure timeline, including acknowledgment of reports within a set period (e.g., 48 hours), triage within 7 days, and target remediation windows based on severity.

3

Coordinated Vulnerability Disclosure Process
Establish a structured CVD process that coordinates with reporters, affected parties, and, where applicable, the designated CSIRT. Ensure reporters are protected and credited where appropriate.

4

Triage & Prioritisation Workflow
Document the internal vulnerability triage workflow, including severity assessment criteria (e.g., CVSS scoring), impact analysis, assignment of responsible teams, and escalation triggers.

5

ENISA Reporting
Establish procedures to notify ENISA of any actively exploited vulnerability within 24 hours of awareness, and a full vulnerability notification within 72 hours, as required by CRA Article 14.

6

Public Advisory Process
Define the process for publishing security advisories once patches are available. Advisories must include vulnerability details, affected versions, remediation guidance, and CVE identifiers where applicable.

CRA Article 13(6) & Article 14 – Vulnerability Handling & Reporting

- Coordinated disclosure policy** – manufacturers must put in place a vulnerability disclosure policy that facilitates reporting by third parties, including security researchers.
- Early warning (24 hours)** – any actively exploited vulnerability must be reported to ENISA within 24 hours of becoming aware of it.
- Full notification (72 hours)** – a detailed vulnerability notification, including severity and impact assessment, must follow within 72 hours.
- Incident reporting** – any severe incident that impacts the security of the product must also be notified to ENISA and relevant CSIRTs.

Step 5 — Test the access-control claim behaviourally

This is the only step that needs the product running. Your instructor will give you the target host. The manufacturer claims the manager API is now authenticated. **Test it rather than reading about it.**

```
# no credential at all – expect 401
curl -sk -o /dev/null -w '%{http_code}\n' -X POST \
  -H 'Content-Type: application/json' -d '{} ' \
  https://<TARGET>:8443/api/agent/1/execute-action

# the CA download must stay open: agents need it before they hold a credential
curl -sk -o /dev/null -w '%{http_code}\n' https://<TARGET>:8443/api/certs/server-ca.crt
```

A **401** on the first and a **200** on the second is the correct result. Then read how it is implemented:

```
wc -l manager/middlewares/auth.go
grep -n "Authenticate()\|RequireRole" manager/routes/routes.go
grep -n "initiated_by\|initiated_from" manager/models/models.go
```

 **Residual gap #3 — authentication is not authorisation.** Read `manager/middlewares/auth.go` carefully and check how many routes are gated by `RequireRole`. You should find exactly one. Then look for organisation scoping in the handlers — there is none, which is why `docs/cra/RISK_ASSESSMENT.md` records risk R-12 with a **single-tenant deployment requirement**. Decide whether Annex I 2(b) is met by authentication alone when any authenticated principal can read across organisations. Say so in your opinion either way.

 There is a second-order consequence worth spotting: agents authenticate with `Authorization: ID <agentID>`, which is an identifier and not a credential. With authentication enforced, enrolled agents receive 401 until they carry a real token. Check whether the manufacturer has documented that rollout.

Step 6 — Test the remediation-safety claim

The product lets a language model choose targets for destructive actions. Verify the guardrails.

```
go test ./manager/helpers/ -run TestValidateActionTarget -v 2>&1 | tail -20
grep -n "ACTION_MODE" manager/config/config.go
```

Read `manager/helpers/targets.go` and answer three questions for your report:

1. What happens if the model returns a private RFC1918 address for `BLOCK_IP`? (*It is refused — which also means the product cannot block an internal attacker. Is that the right trade?*)
2. What happens if it returns `/etc/passwd` for `DELETE_FILE`?
3. Is the same validation applied on the agent, or only on the manager?

 **Residual gap #4 — deletion is still deletion.** Target validation stops the wrong file being chosen, but `DELETE_FILE` is still an unrecoverable `rm -f` with no quarantine and no restore, and `BLOCK_IP` still has no expiry and no reachable `UNBLOCK_IP` path. Check `docs/cra/RISK_ASSESSMENT.md` for whether the manufacturer scored these honestly.

Step 7 — Score all 30 objectives yourself

Go to **Frameworks** → **Objectives**, select framework **CRA**, scope **Asset / Product**, asset **SEUXDR**.

The screenshot shows the 'Objectives Checklist' page in the CYBERFORT RESILIENT EUROPE application. On the left is a dark sidebar with navigation links: Dashboard, Assessments, Frameworks, Objectives (highlighted), Assets / Products, Risks, Controls, Documents, Compliance Chain, and Security Tools. Below these are links for Documentation and AI Assistant, and user information for gkoutidis and CRA Extended with a Sign out button. The main content area is titled 'Objectives Checklist' and contains a 'Framework & Scope Selection' section. This section has two dropdown menus: 'Select Framework' (showing a list with CRA selected) and 'Scope Type' (showing 'Select scope type'). Below these is a large button labeled 'Select a Scope' with a checkmark icon. A message below the button says 'Choose a scope type from the options above to view the objectives checklist'. At the bottom of the main area is an 'AI Compliance Suggestions' section with a sad face icon and the text 'No AI suggestions yet. Click "Auto-select with AI" to generate compliance recommendations.'

Work down all 30 objectives and set a **Compliance Status** based on the evidence *you* gathered, uploading it as you go. Do not copy the manufacturer's grading — the point of the exercise is to arrive at your own and then compare.

The manufacturer's position is 21 compliant, 8 partially compliant, 1 not compliant. When you are done, compare yours against theirs and be ready to defend every difference.

CYBERFORT

RESILIENT EUROPE

Dashboard

Assessments

Frameworks

Objectives

Assets / Products

Risks

Controls

Documents

Compliance Chain

Security Tools

Documentation

AI Assistant

gkoutidis

CRA Extended

Sign out

Objectives Checklist

AI Auto-selectExport PDF

Framework & Scope Selection

Select Framework *

CRA

Scope Type *

Asset / Product

Select Asset / Product

SEUXDR (Software Product)

Scope: Asset / Product - SEUXDR (Software Product)

Chapter II - Obligations of Economic Operators

4 objectives

Subchapter	Objective Title	Requirement Description	Objective Utilities	Policies	Evidence
Internal Security Processes and Controls	Article 25 (Security Measures)	Manufacturers must put in place appropriate and proportionate internal processes and measures to ensure compliance with the CRA.	Information Security Policy, Product Cybersecurity Policy, Management Review Minutes, Information Security Objectives & Plan, Confidentiality Policy, Physical Security Policy, Secure Code Policy, Encryption Policy, Risk Management Policy, Risk Assessment Methodology	Risk Management Policy Approved Software Development Lifecycle Policy Approved Information Security Policy Approved Information Security Objectives And Plan Draft Product Cybersecurity Policy Draft Encryption Policy Review Risk Assessment Methodology Draft Management Review Minutes Draft Physical Security Policy Draft Confidentiality Policy Approved	Upload
Manufacturer Obligations and Responsibilities	Article 13 (Obligations of Manufacturers)	Manufacturers have comprehensive obligations, including ensuring products meet essential requirements, drawing up technical documentation, conducting conformity assessments, providing security updates, and handling vulnerabilities.	Information Security Policy, Organizational Roles, Responsibilities And Authorities, Product Registry Form, Vulnerability Management Policy, Incident Management Policy, Corrective Action Procedures, Product Lifecycle Management (PLM) Policy	Incident Management Policy Draft Information Security Policy Approved Vulnerability Management Policy Approved Organizational Roles Responsibilities And Authorities Draft Product Registry Form Draft Product Lifecycle Management Policy Draft Corrective Action Procedures Draft	Upload
User Documentation and Guidance	Article 26 (Guidance)	Manufacturers should provide users with clear and accessible instructions and information on the secure installation, operation, and maintenance of the product.	Product Registry Form, Information Security Policy, Secure Development Policy, Acceptable use Policy, Vulnerability Management Policy	Software Development Lifecycle Policy Approved Vulnerability Management Policy Approved Information Security Policy Approved Vulnerability Management Policy Approved Product Registry Form Draft	Upload
Vulnerability and Incident Reporting	Article 14 (Reporting of Actively Exploited Vulnerabilities and Incidents)	Manufacturers must report actively exploited vulnerabilities and serious cybersecurity incidents to ENISA and relevant CSIRTs within specified timelines.	Incident Management Policy, Corrective Action Procedures, External Communications Policy, Contact Procedure With Local Authorities	Incident Management Policy Draft Contact Procedure With Local Authorities Draft External Communications Policy Draft Corrective Action Procedures Draft	Upload

Chapter I - General Provisions

2 objectives

Subchapter	Objective Title	Requirement Description	Objective Utilities	Policies	Evidence	Completion
Essential Cybersecurity Requirements	Article 6 (Requirements for Products with Digital Elements) & Annex I (Essential Requirements)	Products with digital elements must meet essential cybersecurity requirements throughout their lifecycle, including security by design, vulnerability management, and incident prevention.	Product Registry Form, Secure Development Policy, Vulnerability Management Policy, Patch Management Policy, Logging And Monitoring Policy	- Patch Management Policy - Software Development Lifecycle Policy - Vulnerability Management Policy - Product Registry Form - Logging And Monitoring Policy	- Draft - Approved - Approved - Draft - Draft	Upload
Scope and Applicability	Article 1 - Subject Matter and Article 2: Scope	Understanding the applicability of the CRA to products with digital elements and key terminology.	Information Security Objectives and Plan, CRA Strategy Policy and Scope, Product Registry Form	- Password Policy - Information Security Policy - Information Security Objectives And Plan - Product Registry Form - CRA Strategy Policy And Scope	- Approved - Approved - Draft - Draft - Draft	Upload

ANNEX I

13 objectives

Subchapter	Objective Title	Requirement Description	Objective Utilities	Policies	Evidence	Completion
Access Control and Authentication	3b	ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems;	Password Policy, Encryption Policy, Access Control Policy, Log and Monitoring Policy, Awareness Policy	- Password Policy - Access Management Policy - Encryption Policy - Logging And Monitoring Policy - Awareness Policy	- Approved - Draft - Review - Draft - Draft	Upload
Attack Surface and Incident Mitigation	3h	Be designed, developed and produced to limit attack surfaces, including external interfaces	Secure Development Policy, Software Development Lifecycle (SDLC), Configuration Management Procedure, Change Management Policy, Vulnerability Management Procedure	- Software Development Lifecycle Policy - Vulnerability Management Policy - Configuration Management Policy - Change Management Policy	- Approved - Approved - Draft - Draft	Upload
Attack Surface and Incident Mitigation	3i	Be designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques;	Secure Development Policy, Vulnerability Management Procedure, Incident Response Plan, System Hardening Standards, Logging and Monitoring Policy	- Incident Management Policy - Software Development Lifecycle Policy - System Hardening Standards - Vulnerability Management Policy - Logging And Monitoring Policy	- Draft - Approved - Draft - Approved - Draft	Upload
		Minimize their own negative				

Availability and Resilience	3g	own negative impact on the availability of services provided by other devices or networks	Incident Response Plan, Logging and Monitoring Policy	● Incident Management Policy ● Logging And Monitoring Policy	● Draft ● Draft	Upload	Select
Availability and Resilience	3f	protect the availability of essential functions, including the resilience against and mitigation of denial of service attacks;	Monitoring and Logging Policy, Network Security Policy, Availability Policy	● Availability Policy ● Logging And Monitoring Policy ● Network Management Policy	● Draft ● Draft ● Draft	Upload	Select
Data Protection	3d	Protect the integrity of stored, transmitted or otherwise processed data, commands, programs and configuration against manipulation or modification	Change Management Policy, Encryption Policy, Secure Development Policy, Logging and Monitoring Policy, Access Control Policy	● Software Development Lifecycle Policy ● Access Management Policy ● Encryption Policy ● Logging And Monitoring Policy ● Change Management Policy	● Approved ● Draft ● Review ● Draft ● Draft	Upload	Select
Data Protection	3e	process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended use of the product ('minimisation of data');	Data Retention Policy, Data Protection Policy, Access Control Policy, Third-Party Data Processing Policy, Product Registry Entry	● Access Management Policy ● Data Classification Policy ● Data Retention Policy ● Product Registry Form	● Draft ● Draft ● Draft ● Draft	Upload	Select
Data Protection	3c	Protect the confidentiality of stored, transmitted or otherwise processed data through encryption	Encryption Policy	● Encryption Policy	● Review	Upload	Select
Secure Configuration Management	3a	Be delivered with a secure by default configuration, including the possibility to reset the product to its original state	Asset Management Policy, Secure Coding Policy, Password Policy, Encryption Policy, Information Security Policy, Configuration Management Policy	● Software Development Lifecycle Policy ● Password Policy ● Information Security Policy ● Encryption Policy ● Configuration Management Policy ● Asset Management Policy	● Approved ● Approved ● Approved ● Review ● Draft ● Draft	Upload	Select
Secure Product Design and Development	1	Products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks	Comprehensive Secure Development Lifecycle (SDLC) policy document, Vulnerability Management Policy, Acceptable Use Policy	● Software Development Lifecycle Policy ● Vulnerability Management Policy ● Vulnerability Management Policy	● Approved ● Approved ● Approved	Upload	Select
Secure Product Design and Development	2	Products with digital elements shall be delivered without any known exploitable vulnerabilities	Vulnerability Management Policy, Patch Management Policy	● Patch Management Policy ● Vulnerability Management Policy	● Draft ● Approved	Upload	Select

Security Monitoring and Logging	3j	provide security related information by recording and/or monitoring relevant internal activity, including the access to or modification of data, services or functions;	Logging and Monitoring Policy, Privileged Access Management Procedure	- Access Management Policy - Logging And Monitoring Policy	• Draft • Draft	Upload	Select
Security Update Management	3k	ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic updates and the notification of available updates to users.	Vulnerability Management Procedure, Secure Development Policy, Software Update and Patch Management Policy, Change Management Policy	- Risk Management Policy - Patch Management Policy - Software Development Lifecycle Policy - Vulnerability Management Policy - Change Management Policy	• Approved • Draft • Approved • Approved • Draft	Upload	Select

Chapter V - Market Surveillance, Control of Products with Digital Elements Entering the Union Market and Union Safeguard Procedure

2 objectives

Subchapter	Objective Title	Requirement Description	Objective Utilities	Policies	Evidence	Comp
Continuous Evaluation and Improvement	Article 70 (Evaluation and Review)	The Commission will evaluate the CRA, highlighting the importance of ongoing performance assessment by economic operators.	Performance Measurement Policy, Management Review Procedure, Information Security Objectives & Plan, Information Security Policy, Information Security Communication Plan	- Information Security Policy - Information Security Objectives And Plan	• Approved • Draft	Upload Select
Market Surveillance and Compliance Monitoring	Article 52 (Market Surveillance Authorities) & Article 54 (Procedure at National Level for Products Presenting a Cybersecurity Risk)	Market surveillance authorities will monitor compliance, and procedures are in place for addressing non-compliant products.	Internal Audit Procedure, Corrective Action Procedures, Information Security Policy, Procedure For Control Of Documented Information, Management Review Procedure, Information Security Communication Plan	- Information Security Policy - Corrective Action Procedures	• Approved • Draft	Upload pa

Vulnerability Handling

8 objectives

Subchapter	Objective Title	Requirement Description	Objective Utilities	Policies	Evidence	C
		ensure that, where ..				

Security Update Distribution	8	security patches or updates are available to address identified security issues, they are disseminated without delay and free of charge, accompanied by advisory messages providing users with the relevant information, including on potential action to be taken.	Security Patch Management Policy, Security Advisory Communication Procedure, Incident Response Plan, Vulnerability Disclosure Policy	● Incident Management Policy ● Patch Management Policy ● Vulnerability Management Policy ● Security Advisory Communication Procedure	● Draft ● Draft ● Approved ● Draft	Upload
Security Update Distribution	7	provide for mechanisms to securely distribute updates for products with digital elements to ensure that exploitable vulnerabilities are fixed or mitigated in a timely manner;	Patch Management and Update Policy, Secure Software Delivery Procedure, Change Management Policy, Monitoring and Logging Policy, Product Lifecycle and Support Policy	● Patch Management Policy ● Secure Software Delivery Procedure ● Logging And Monitoring Policy ● Product Lifecycle And Support Policy ● Change Management Policy	● Draft ● Draft ● Draft ● Draft ● Draft	Upload
Vulnerability Disclosure	5	put in place and enforce a policy on coordinated vulnerability disclosure;	Vulnerability Management Policy, Incident Response Plan	● Incident Management Policy ● Vulnerability Management Policy	● Draft ● Approved	Upload
Vulnerability Disclosure	6	take measures to facilitate the sharing of information about potential vulnerabilities in their product with digital elements as well as in third party components contained in that product, including by providing a contact address for the reporting of the vulnerabilities discovered in the product with digital elements;	Vulnerability Management Policy, Third-Party Security Policy	● Vulnerability Management Policy ● Vendor Management Policy	● Approved ● Draft	Upload
Vulnerability Disclosure	4	once a security update has been made available, publically disclose information about fixed vulnerabilities, including a description of the vulnerabilities, information allowing users to identify the product with digital elements	Incident Response and Communication Plan, Security Communications Plan, Secure Development Policy	● Incident Management Policy ● Software Development Lifecycle Policy ● Security Communications Plan	● Draft ● Approved ● Draft	Upload

		affected, the impacts of the vulnerabilities, their severity and information helping users to remediate the vulnerabilities;					
Vulnerability Identification and Testing	3	apply effective and regular tests and reviews of the security of the product with digital elements;	Secure Development Lifecycle (SDLC) Policy, Vulnerability Management Policy	● Software Development Lifecycle Policy ● Vulnerability Management Policy	● Approved ● Approved	Upload	
Vulnerability Identification and Testing	2	In relation to the risks posed to the products with digital elements, address and remediate vulnerabilities without delay, including by providing security updates;	Vulnerability Management Procedure, Security Patch and Update Policy, Change Management Policy, Threat Intelligence and Monitoring Procedure	● Patch Management Policy ● Vulnerability Management Policy ● Change Management Policy	● Draft ● Approved ● Draft	Upload	
Vulnerability Identification and Testing	1	identify and document vulnerabilities and components contained in the product, including by drawing up a software bill of materials in a commonly used and machine-readable format covering at the very least the top-level dependencies of the product;	Product Registry Entry, Third-Party Software Policy, Secure Development Policy, Vulnerability Management Procedure, Supply Chain Risk Management Policy, Release Management Procedure	● Software Development Lifecycle Policy ● Vulnerability Management Policy ● Release Management Procedure ● Product Registry Form ● Vendor Management Policy	● Approved ● Approved ● Draft ● Draft ● Draft	Upload	

Chapter III - Conformity of the Products with Digital Elements

1 objective

Subchapter	Objective Title	Requirement Description	Objective Utilities	Policies	Evidence	Compliance Status
Conformity Assessment and Documentation	Article 28 (EU Declaration of Conformity) & Annex V (Technical Documentation)	Manufacturers must draw up an EU declaration of conformity and compile technical documentation demonstrating that the product meets the essential requirements.	EU Declaration of Conformity Template, Product Registry Form, Procedure For Control Of Documented Information	● Product Registry Form	● Draft Upload	● partially compliant

AI Compliance Suggestions



No AI suggestions yet. Click "Auto-select with AI" to generate compliance recommendations.

💡 Two objectives should be straightforward passes and are worth understanding as examples of good evidence: Annex I **3f** (availability — the failed-alert queue, dead-letter queue and resume-after-restart) and **3j** (security-event recording — structured logging with correlation IDs and a persisted AI reasoning trail). Read the code behind both. This is what a defensible **Yes** looks like.

Step 8 — Complete the conformity assessment

Assessments → **+ New Assessment**: framework **CRA**, type **Conformity**, scope **Asset / Product** → **SEUXDR**, name it with your own surname so your instructor can find it.

The screenshot displays the Cyberfort Resilient Europe assessment interface. On the left is a dark sidebar with navigation links: Dashboard, Assessments (active), Frameworks, Assets / Products, Risks, Controls, Documents, Compliance Chain, and Security Tools. Below these are links for Documentation, AI Assistant, and user information (gkoutidis, CRA Extended, and a Sign out button). The main area shows three assessment questions. Each question has a status bar (Mandatory: YES, Completed: NO, Common in: CRA(clone-systems.com)), a question text, radio button options (Yes, No, Partially, N/A), an Assign Policy dropdown (set to No Policy), an Evidence Description text area, and an Attach File(s) button. The questions are: Question 1: 'Have you undertaken an assessment of the cybersecurity risks associated with your product with digital elements?'; Question 2: 'Do you take the outcome of the cybersecurity risk assessment into account during the planning, design, development, production, delivery and maintenance phases?'; and Question 3: (partially visible). Each question has a Save Answer button on the right.

Answer all 52 questions. For each one, write an **Evidence Description** naming the file or the platform artefact you relied on, and attach the scan output where you have it.

⚠️ Answer honestly. The temptation on a remediated product is to mark things **Yes** because the documentation says so. Six of these questions cannot honestly be **Yes** on this release — find them. If your distribution comes out dramatically better than the manufacturer's own, you have probably accepted a document at face value somewhere.

Step 9 — Write the assessor's opinion

Export the pack: **Assessments** → **Export PDF**, **Frameworks** → **Objectives** → **Export PDF**, and **Compliance Chain** → **Gap Analysis** → **Export PDF**.

CYBERFORT

RESILIENT EUROPE

Dashboard

Assessments

Frameworks

Assets / Products

Risks

Controls

Documents

Compliance Chain

All Links

Map

Gap Analysis

Security Tools

Documentation

AI Assistant

gkoutidis

CRA Extended

Sign out

Gap Analysis

CRA

Export PDF

Compliance Overview

60

Total Objectives

8

Compliant Objectives

0 / 1

Assessments Comple...

7

Approved Policies

10%

Overall Score

Objectives Compliance

Status Breakdown

Compliant

8

Partially Compliant

6

Not Compliant

0

In Review

4

Not Assessed

42

Not Applicable

0

Evidence Coverage

0 of 60 objectives have evidence attached

0%

With evidence: 0

Without evidence: 60

Policy Coverage

7

Approved Policies (14.6%)

Approved

7

Draft

40

Review

1

Objective-Policy Linkage

56 of 60 objectives linked to policies

93.3%

Linked: 56

Unlinked: 4

Assessment Progress

0%

Assessment Details

Total Assessments

1

Completed

0

In Progress

1

Average Progress

0%

Unanswered Questions

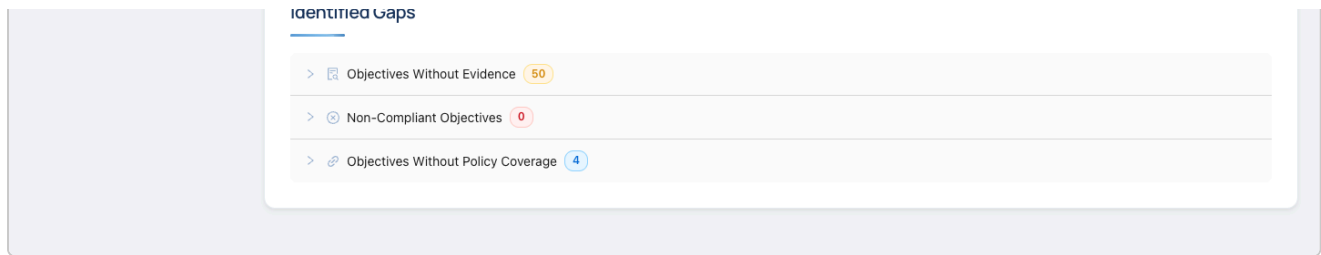
52

Total Questions

52

Chapter Breakdown

Chapter	Total	Compliant	Not Compliant	Not Assessed	Rate
Chapter I - General Provisions	4	4	0	0	100%
Chapter II - Obligations of Economic Operators	8	3	0	1	37.5%
Chapter III - Conformity of the Products with Digital Elements	2	0	0	0	0%
Chapter V - Market Surveillance, Control of Products with Digital Elements Enterin...	4	0	0	2	0%
ANNEX I	26	0	0	26	0%
Vulnerability Handling	16	1	0	13	6.2%



Then write **one page** answering three questions:

1. **Is the manufacturer's 70% claim supportable?** Give a number of your own and justify the difference.
2. **What blocks a Declaration of Conformity today?** Rank them.
3. **What would you require before signing?** Be specific enough that an engineer could act on it.

🔴 **Residual gap #5 — the score is not the conclusion.** Read `docs/PILOT_TIMELINE.md` and note that the platform exposes three different CRA percentages measuring three different things. If your opinion quotes a percentage, say which one and at what scope. An assessor who quotes a number without its denominator has not finished the job.

Step 10 — Stretch goals (optional)

- Deploy the **baseline** product (`00a95ad`) alongside and run the same `curl` from Step 5. Watch the same request succeed with no credential, then re-run the objectives checklist against it and see the position collapse to 2 of 30.
- Draft the missing **organisation-scoping** requirement as a risk-register entry with a treatment plan.
- Use **Security Tools** → **VEX Statements** to publish a CycloneDX VEX for one advisory the dependency scan raised, and explain why VEX matters more than the SBOM alone.
- Use the **AI Assistant** to draft the assessor's opinion, then mark up everything it overstated. That exercise is the point, not the draft.

Checklist

Tick these off before declaring the scenario complete.

- ☐ Product version and classification verified, Article 32(2) consequence stated
- ☐ SBOM generated and compared against the manufacturer's SBOM policy
- ☐ Dependency and code scans run; policy claims tested against `go.mod` and `package.json`
- ☐ All six vulnerability-handling artefacts confirmed present and assessed for quality
- ☐ Access control tested behaviourally with `curl`, not just read about
- ☐ Remediation-safety guardrails read and the three questions answered
- ☐ All 30 objectives graded independently, with evidence attached
- ☐ All 52 conformity questions answered with evidence descriptions
- ☐ Readiness pack exported (assessment, objectives, gap analysis)
- ☐ One-page assessor's opinion written, with a defended number and a ranked blocker list